

# Riesgos de IT

## Metodologías de evaluación

El análisis de riesgos es un proceso recurrente que debe ajustar las decisiones de la organización o plantear cambiar el “apetito de riesgo” según se vayan logrando resultados que manifiesten el control de los riesgos que se están ya gestionando. Para ello, debe realizarse el proceso de identificación del riesgo a intervalos planificados o cuando se plantee u ocurran cambios significativos, tomando acciones según los criterios de aceptación del riesgo.

Para el tratamiento del riesgo, la organización estará implantando el plan de tratamiento del riesgo. Conforme se logren ciertos hitos, se irán modificando los criterios de aceptación del riesgo y eso provocará que año tras año los planes se vayan también actualizando para reflejar la nueva toma de decisiones. Por tanto, la gestión de la seguridad implica la ejecución continuada del plan de tratamiento que año tras año se debe también revisar.

Gestionar los riesgos significa administrarlos para lograr un balance apropiado entre darse cuenta de las oportunidades de los beneficios (maximizar ganancias y minimizar pérdidas) y a la vez minimizar los aspectos negativos o impactos adversos.

Es una parte esencial de una buena práctica gerencial y un elemento fundamental a la hora de establecer un buen gobierno corporativo. (Incorporado a la cultura de la empresa)

Es un proceso de desarrollo iterativo, lógico, sistematizado, multifacético e interdisciplinario tendiente a:

- Identificar.
- Analizar
- Evaluar.
- Monitorear.
- Comunicar

Los riesgos asociados a actividades y procesos de la organización:

- Busca acotar la **incertidumbre** que presentan las amenazas y las oportunidades en las empresas.

- El diseño e implementación de un sistema de gestión de riesgos está influenciado por las necesidades propias de cada organización, sus objetivos, procesos y prácticas específicas.

## Concepto de amenaza, vulnerabilidad, riesgo y exposición o impacto

Algunas definiciones:

### Evento

Hecho imprevisto o que puede suceder.

### Amenaza

Es todo aquel evento (realizado por personas, cosas, etc.) que puede ser visto como posible peligro/catástrofe para la empresa (por ejemplo: inundaciones, incendio, virus/malware, robo de información, sabotajes, etc.). Daño potencial asociado con una explotación de una vulnerabilidad.

### Vulnerabilidad

Explotación de una amenaza. Es cualquier situación creada por la falta de controles por los cuales una amenaza puede suceder. Es un riesgo alto (por ejemplo: falta de controles de acceso lógico, falta adecuada de separación de ambientes, etc.).

### Riesgo

Posibilidad de que suceda algo que tendrá impacto en los objetivos de la empresa. Se mide en términos de combinar la probabilidad de un evento y su consecuencia. Probabilidad de que se materialice una amenaza.

### Probabilidad

Intervalo dentro del cual es probable que ocurra un evento.

### Exposición / Impacto

Es la evaluación (por lo general económica) del efecto del riesgo. También es posible evaluarlo en función de otras variables como:

- Vidas humanas.
- Imagen de la empresa / reputación.

- Implicancias legales.

### Riesgo residual

Nivel riesgo restante luego de haberlo tratado.

## Metodologías cuantitativa y cualitativa

Existen dos tipos de riesgos:

### *Cuantitativo*

Asigna valores monetarios y numéricos (*hard-objetivos*) a cada componente del proceso de evaluación de riesgos y a cada pérdida potencial.

Representa la probabilidad de ocurrencia e impacto de los riesgos.

**SLE (*Single Loss Expectancy*) = valor del activo x factor de exposición (FE)**

- Representa una pérdida potencial, en una organización, si una amenaza se llegara a producir.

**EF (o FE - *Exposure Factor*) = valor de exposición**

- Representa el % de pérdida que habría en un activo específico.

Un ejemplo:

Activo: **Data Warehouse**

Valoración: U\$S 150.000

Se ha estimado que en caso de que ocurriera un incendio, el 25% de este activo podría verse afectado.

$$\text{SLE (37.500)} = \text{Valor del Activo (150.000)} \times \text{FE (25\%)}$$

La compañía tendría una **pérdida potencial** de U\$S 37.500 si ocurriera un incendio.

### *Cualitativo*

Utiliza elementos *soft* de la organización (opinión, mejores prácticas, intuición, experiencia, etc.), para ponderar el riesgo y sus componentes. No asigna números y valores monetarios a los componentes y pérdidas. Representa la probabilidad de ocurrencia e impacto de los riesgos.

**ALE (Annual Loss Expectancy) = expectativa de pérdida anual**

- Si la amenaza se volviera real

**ARO (Annualized Rate of Occurrence) = tasa de ocurrencia anual**

- Valor estimativo de una amenaza específica en 12 meses.
- Tiene un rango que va:
  - 0.0 (nunca).
  - 1.0 (1 vez por año).
  - >1 (+ de 1 vez por año)

**SLE x ARO = ALE**

Tomando el ejemplo anterior:

Activo: **Data Warehouse**

Valoración: U\$S 150.000

Se ha estimado que la probabilidad de que ocurra un incendio y que este a su vez afectara al Data Warehouse equivale a **una vez cada diez años**, el valor del ARO es de 0.1

$$ALE (3.750) = SLE (37.500) \times ARO (0.1)$$

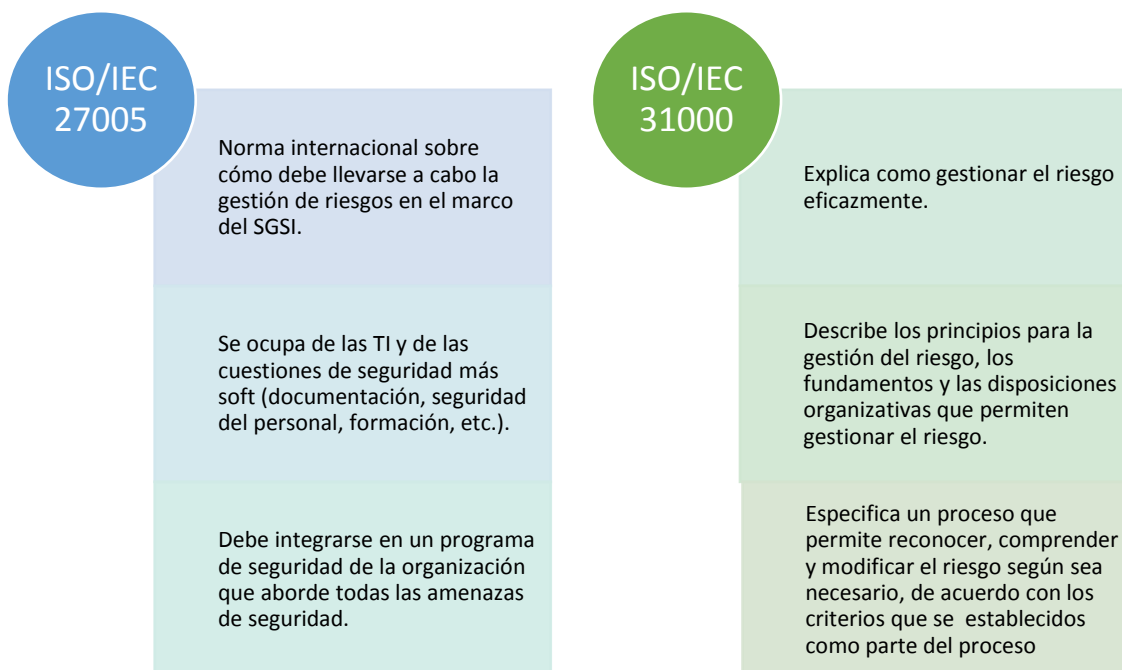
El valor que arroja el coeficiente ALE indica que si la empresa quiere implementar un control para proteger el data Warehouse contra incendios (amenaza), debería **invertir** U\$S 3.750 ó menos (por año) para suministrar el nivel adecuado de protección.

## Metodologías comúnmente utilizadas

| Nombre                                                                                             | Descripción                                                                                                                                                                                                         |
|----------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIST 800-30</b>                                                                                 | Documento considerado como estándar para U.S.Federal. Es específico para las amenazas en TI con foco en componentes operativos                                                                                      |
| <b>CRAMM (Central Computing and Telecommunications Agency Risk Analysis and Management Method)</b> | Creada por el Reino Unido. Herramienta automática que es vendida por Siemens. Trabaja en tres fases o pasos -> <ol style="list-style-type: none"> <li>1. Definir objetivos.</li> <li>2. Evaluar riesgos.</li> </ol> |

|                                                                                    |                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                    | 3. Identificar las contramedidas.                                                                                                                                                                                                |
| <b>FRAP (Facilitated Risk Analysis Process)</b>                                    | Se usa para analizar un sistema, aplicativo o proceso de negocio. El foco está en los sistemas que necesitan realmente reducir costos y tiempos.                                                                                 |
| <b>OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation)</b> | Creado por y Carnegie Mellon University's Software Engineering Institute (EEUU). Se usa para evaluar todos los activos, sistemas, aplicaciones y riesgos de negocios. Foco en amenazas y riesgos en Seguridad de la Información. |

## Norma ISO/IEC 27005 e ISO/IEC 31000



## Referencias

- CISSP Sixth Edition – Shon Harris Mc Graw Hill
- En español: <http://www.iso27000.es/>
- En inglés: <http://www.iso27001security.com/>
- IRAM ISO 31004 - Gestión del riesgo - Guía para la implantación de la ISO 31000
- ISO/IEC 27000 en iso.org: <https://www.iso.org/obp/ui/#iso:std:iso-iec:27000:ed-3:v1:en>